

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01 Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I Y.HEMA SAI LAHARI(192311446)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Y.HEMA SAI LAHAERI

S. No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding (20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities (20)	Accurately identifies vulnerabilities related to wireless standards,	Identifies most major vulnerabilities with reasonable	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or	

		encryption, authentication, access points, configuration, and network architecture.	explanation.		provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and	Report is well-structured, professionally written,	Report is clear and organized with	Report is understandable but	Report is poorly organized, unsupported, or contains major	

	Presentation(20)	supported by reliable references, diagrams, tables, and a clear risk-rating summary.	suitable evidence and references.	lacks organization, evidence, or proper referencing.	presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate

authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable use policies, and legal consequences.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue access-point detection, staff response procedures, and user-verification methods.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

1. TJX COMPANIES WIRELESS NETWORK BREACH, 2005–2007

1.1 Introduction

TJX Companies experienced a major payment-card data breach between 2005 and 2007. Attackers gained unauthorized access through weaknesses in the company's wireless network. The incident demonstrated the security risks associated with obsolete wireless encryption, inadequate network segmentation, weak monitoring, and insufficient protection of payment information.

1.2 Vulnerability Assessment

Wireless Encryption

TJX used WEP during its transition toward stronger wireless security. WEP is an outdated encryption technology and can be compromised using relatively practical attacks. Sensitive payment-related communication should not depend on obsolete encryption.

Risk: High

Authentication

Weak wireless authentication can allow unauthorized devices to connect to the corporate network. Strong enterprise authentication should be used instead of shared or weak credentials.

Risk: High

Network Segmentation

Wireless users should not have unrestricted access to payment-processing systems. Failure to properly separate wireless networks from sensitive systems increases the impact of a compromise.

Risk: Critical

Monitoring

Insufficient monitoring can allow attackers to remain undetected. Wireless intrusion detection and centralized security logging should be implemented.

Risk: High

Payment-Data Protection

Payment-card information requires strong protection through encryption, access control, tokenization where appropriate, and PCI DSS security controls.

Risk: Critical

1.3 Recommendations

- Replace WEP with WPA2-Enterprise or WPA3-Enterprise.

- Use 802.1X authentication with an appropriate EAP method.
- Implement strong certificate validation.
- Separate wireless networks from payment-processing systems.
- Deploy wireless intrusion detection and prevention systems.
- Encrypt sensitive payment information.
- Apply PCI DSS requirements to cardholder-data environments.
- Maintain centralized security logs and continuous monitoring.
- Conduct regular vulnerability assessments and penetration tests.

1.4 Conclusion

The TJX incident demonstrates that obsolete encryption, weak authentication, inadequate segmentation, and insufficient monitoring can turn a wireless weakness into a major data breach. Modern wireless security and PCI DSS controls could significantly reduce such risks.

TJX Companies Wireless Network Breach (2005–2007)

Objective

To perform a basic wireless network security assessment in Kali Linux and identify wireless interfaces, available networks, security types, IP configuration, and connection status.

Tools Used

- Kali Linux
- Terminal
- iw
- iwconfig
- nmcli
- ip
- ping

1. Identify the Wireless Interface

Command

```
iw dev
```

Output

```
phy#0
```

```
Interface wlan0
    ifindex 3
    wdev 0x1
    addr xx:xx:xx:xx:xx:xx
    type managed
```

Figure 1: Wireless Interface Identification in Kali Linux

Observation:

The command identifies the wireless interface available on the Kali Linux system. In this example, the wireless interface is wlan0.

2. Display Wireless Network Information

Command

```
iwconfig
```

Output

```
wlan0 IEEE 802.11
    Mode:Managed
    ESSID:"Campus_WiFi"
    Access Point: XX:XX:XX:XX:XX:XX
    Bit Rate:54 Mb/s
    Link Quality=70/70
    Signal level=-40 dBm
```

Figure 2: Wireless Interface Configuration

Observation:

The command displays the wireless mode, connected SSID, access point, signal quality, and other wireless parameters.

3. Scan Available Wi-Fi Networks

Command

```
nmcli dev wifi list
```

Output

IN-USE	BSSID	SSID	MODE	CHAN	RATE	SIGNAL	BARS	SECURITY
*	XX:XX:XX:XX:XX:01	Campus_WiFi	Infra	6	54 Mbit/s	80		WPA2
	XX:XX:XX:XX:XX:02	Guest_WiFi	Infra	11	54 Mbit/s	65		WPA2
	XX:XX:XX:XX:XX:03	Office_WiFi	Infra	36	866 Mbit/s	75		WPA3

Figure 3: Available Wireless Networks and Security Types

Observation:

The command displays nearby wireless networks along with their SSIDs, channels, signal strength, and security mechanisms. Modern WPA2/WPA3 security provides stronger protection than obsolete WEP.

4. Display Wireless Security Information

Command

```
nmcli -f IN-USE,SSID,CHAN,SIGNAL,SECURITY dev wifi list
```

Output

IN-USE	SSID	CHAN	SIGNAL	SECURITY
*	Campus_WiFi	6	80	WPA2
	Guest_WiFi	11	65	WPA2
	Office_WiFi	36	75	WPA3

Figure 4: Wireless Security Assessment

Observation:

The output helps identify the security mechanisms used by visible wireless networks. Strong encryption such as WPA2 or WPA3 should be preferred over outdated WEP.

5. Check IP Address Configuration

Command

```
ip addr show
```

Output

```
3: wlan0:
    inet 192.168.1.25/24
    inet6 fe80::xxxx/64
```

state UP

Figure 5: Wireless IP Configuration

Observation:

The command displays the IP address and operational state of the wireless interface. This information helps verify network connectivity and configuration.

6. Check Network Routes

Command

```
ip route
```

Output

```
default via 192.168.1.1 dev wlan0  
192.168.1.0/24 dev wlan0 proto kernel scope link
```

Figure 6: Network Routing Information

Observation:

The routing table identifies the default gateway and the network connected to the wireless interface.

7. Check Wireless Device Status

Command

```
nmcli device status
```

Output

DEVICE	TYPE	STATE	CONNECTION
wlan0	wifi	connected	Campus_WiFi
lo	loopback	unmanaged	--

Figure 7: Wireless Device Status

Observation:

The command confirms whether the wireless adapter is connected and identifies the active wireless connection.

8. Test Network Connectivity

Command

```
ping -c 4 8.8.8.8
```

Output

64 bytes from 8.8.8.8: icmp_seq=1 ttl=117 time=25 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=117 time=24 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=117 time=26 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=117 time=25 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss

Figure 8: Network Connectivity Test

Observation:

The successful response indicates that the system has network connectivity.

Vulnerability Assessment Findings

Vulnerability	Risk Level	Recommended Control
Outdated WEP encryption	Critical	WPA2/WPA3
Weak authentication	High	802.1X / Enterprise Authentication
Poor network segmentation	Critical	VLANs and Firewalls
Insufficient wireless monitoring	High	WIDS/WIPS
Payment-data exposure	Critical	PCI DSS controls and encryption

Recommendations

1. Replace obsolete WEP with WPA2-Enterprise or WPA3-Enterprise.
2. Implement 802.1X-based enterprise authentication.
3. Separate wireless networks from payment-processing systems.
4. Use firewalls and VLANs for network segmentation.
5. Deploy Wireless Intrusion Detection and Prevention Systems.
6. Encrypt sensitive payment information.

7. Apply PCI DSS security controls.
8. Enable centralized logging and continuous monitoring.

Conclusion

The Kali Linux assessment demonstrates how basic wireless information can be collected for security evaluation. The TJX incident highlights the importance of strong wireless encryption, enterprise authentication, network segmentation, monitoring, and payment-data protection. Implementing WPA2/WPA3, 802.1X, WIDS/WIPS, and PCI DSS controls can significantly reduce similar risks.